

漏洞分析报告

漏洞名称	【AngularJS 表达式 DOM XSS】
测试平台	PortSwigger Web Security Academy
漏洞类型	【XSS】
风险等级	中危
测试时间	2026 年

一、漏洞原理

DOM 型 XSS 是指漏洞发生在浏览器端，JavaScript 直接将用户输入写入页面 DOM 中，数据不经过服务器处理。本实验中，目标网站使用了 AngularJS 框架，页面对用户输入的尖括号和双引号进行了 HTML 编码，无法直接注入 HTML 标签。但 AngularJS 会自动解析双花括号 `{{ }}` 中的表达式，攻击者可通过构造特殊的 AngularJS 表达式（如利用 `constructor` 属性访问 `Function` 构造器），绕过沙箱限制执行任意 JavaScript 代码。

二、漏洞危害

攻击者可构造包含恶意 AngularJS 表达式的链接，诱导用户点击后在其浏览器中执行任意 JavaScript 代码，可能导致窃取用户 Cookie 和会话信息、伪造用户操作、钓鱼攻击、以及获取用户敏感数据。

三、复现过程

3.1 测试环境

测试平台：PortSwigger Web Security Academy 靶场

使用工具：浏览器

3.2 测试步骤

Step 1: 确认源码为 AngularJS 框架

```

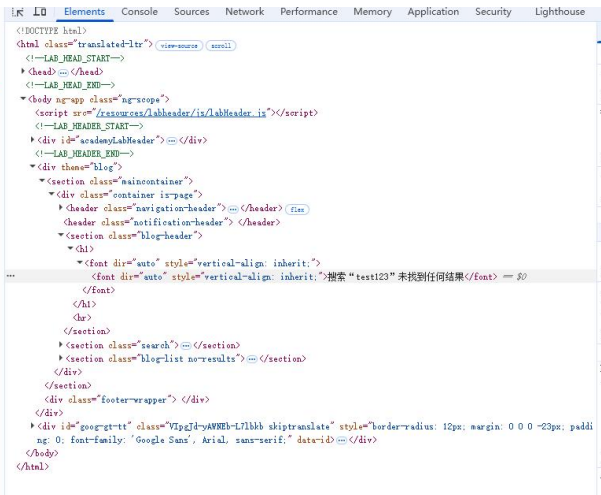
3<!--LAB_HEAD_START-->
4<head>
5<link href="/resources/labheader/css/academyLabHeader.css" rel="stylesheet">
6<link href="/resources/css/labsBlog.css" rel="stylesheet">
7<script type="text/javascript" src="/resources/js/angular 1-7-7.js"></script>
8<title>DOM XSS in AngularJS expression with angle brackets and double quotes HTML-encoded</title>
9</head>
10<!--LAB_HEAD_END-->
11<body ng-app>
12<script src="/resources/labheader/js/labHeader.js"></script>
13<!--LAB_HEADER_START-->
14<div id="academyLabHeader">
15<section class='academyLabBanner is-solved'>
16<div class=container>
17<div class=logo></div>
18<div class=title-container>
19<h2>DOM XSS in AngularJS expression with angle brackets and double quotes HTML-encoded</h2>
20<a class=link-back href='https://portswigger.net/web-security/cross-site-scripting/dom-based/lab-angular-is-expression'>

```

确认页面加载了 AngularJS 1.7.7，并且整个 body 都在 AngularJS 作用域内

在搜索框输入 test123，出现在 h1 标签

漏洞，该漏洞利用 J 大括号和双引号，并进行了 HTML 编码。



Step 2: 尝试常规 XSS 失败，尖括号被编码

搜索“<script>alert(1)</script>”未找到任何结果



Step 3: 尝试输入 AngularJS 表达式{{1+1}}，显示 2，确认存在 AngularJS 模板注入点

搜索“2”未找到任何结果

搜索

[< 返回博客](#)

Step 4: 构造 payload: `{{${on.constructor('alert(1'))()}}`

成功弹窗，XSS 攻击成功



四、注意事项

该漏洞属于 DOM 型 XSS，payload 不经过服务器，因此服务端 WAF 无法检测。此外，HTML 编码无法防御 AngularJS 表达式注入，需针对模板注入进行专门防护。

五、修复建议

修复方案	说明
升级或移除 AngularJS	AngularJS 已停止维护，建议迁移至 Angular（2+），其默认启用更严格的安全策略
CSP 内容安全策略	配置 Content-Security-Policy 头，禁止内联脚本执行，限制可信脚本来源
输入过滤与转义	对用户输入中的花括号等 AngularJS 特殊字符进行过滤或转义

六、参考资料

- PortSwigger Web Security Academy: <https://portswigger.net/web-security>
- OWASP Top 10: <https://owasp.org/Top10/>